RAPPORT DE VEILLE TECHNOLOGIQUE

Certification & Authentification réseau

EAP-TLS

Extensible Authentication Protocol – Transport Layer Security

Période de veille	Septembre 2024 – Avril 2026
Durée totale	19 mois
Auteur	Léo Pernin — BTS Sio SISR
Établissement	Lycée Pasteur Mont-Roland
Date de rendu	Avril 2026

Sommaire

1. Présentation du thème

1.1 Qu'est-ce qu'EAP-TLS ?

1.2 Fonctionnement technique

1.3 Positionnement dans l'écosystème

1.4 Contexte et motivations personnelles

2. Outils et méthodes de veille utilisés

2.1 Outils de surveillance

2.2 Sources consultées

2.3 Fréquence et méthode

3. Événements marquants (Chronologie)

3.1 Septembre – Décembre 2024

3.2 Janvier – Juin 2025

3.3 Juillet – Décembre 2025

3.4 Janvier – Avril 2026

4. Résultats, Analyse et Conclusion

1. Présentation du thème

1.1 Qu'est-ce qu'EAP-TLS ?

EAP-TLS (Extensible Authentication Protocol – Transport Layer Security) est un protocole d'authentification réseau basé sur des certificats numériques. Il constitue l'une des méthodes d'authentification les plus sécurisées disponibles à ce jour pour les réseaux filaires et sans fil (Wi-Fi).

Défini à l'origine par la RFC 5216 (2008) puis mis à jour par la RFC 9190 (2022) pour intégrer TLS 1.3, EAP-TLS s'appuie sur une infrastructure à clés publiques (PKI) pour effectuer une authentification mutuelle entre le client et le serveur.

Contrairement à des méthodes comme PEAP-MSCHAPv2 qui reposent uniquement sur un mot de passe, EAP-TLS exige la présence d'un certificat numérique côté client ET côté serveur, ce qui élimine les risques d'attaques par usurpation d'identité (MITM) et d'attaques par dictionnaire.

1.2 Fonctionnement technique

EAP-TLS s'inscrit dans une architecture 802.1X composée de trois acteurs principaux :

- Le Supplicant : le client (PC, smartphone, objet IoT) qui souhaite s'authentifier
- L'Authenticator : le point d'accès Wi-Fi ou le commutateur réseau
- Le Serveur d'authentification : un serveur RADIUS (ex. FreeRADIUS, NPS Microsoft)

Le processus d'authentification se déroule en plusieurs étapes :

- Le point d'accès reçoit la demande de connexion et la relaie au serveur RADIUS
- Le serveur RADIUS envoie un challenge EAP-TLS au client (démarrage du handshake TLS)
- Le client présente son certificat numérique au serveur
- Le serveur vérifie la validité du certificat (chaîne de confiance, révocation OCSP/CRL)
- Le serveur présente à son tour son propre certificat au client
- En cas de succès mutuel, les clés de session sont dérivées et la connexion est accordée
- Le trafic réseau est ensuite chiffré via WPA2-Enterprise ou WPA3-Enterprise

1.3 Positionnement dans l'écosystème

EAP-TLS est considéré comme le standard de référence pour les environnements à haute sécurité. Il est notamment :

- La seule méthode EAP autorisée en mode WPA3-Enterprise 192 bits
- Obligatoire pour la conformité à certains référentiels (ISO 27001, PCI-DSS, certaines normes gouvernementales)
- Largement déployé dans les universités, grandes entreprises, et infrastructures critiques
- Recommandé dans les architectures Zero Trust Network Access (ZTNA)

1.4 Contexte et motivations personnelles

J'ai choisi d'orienter mon sujet autour de cette technologie car l'authentification par certificat via EAP-TLS a été récemment mise en place au sein de mon entreprise, ce qui me permet d'aborder ce thème à partir d'un contexte réel et concret.

En effet, des travaux de modernisation de notre architecture réseau ont été réalisés. Lors d'un audit des équipements connectés au réseau Wi-Fi professionnel, nous avons constaté que plusieurs utilisateurs connectaient leurs appareils personnels (smartphones, ordinateurs portables, tablettes) au réseau interne de l'entreprise.

Cette situation nous exposait à un risque de sécurité important, car ces équipements ne sont pas maîtrisés par le service informatique. Nous n'avions aucun contrôle sur leur niveau de sécurité ni sur leur état de mise à jour, ce qui augmentait le risque d'introduction de failles internes ou de propagation de logiciels malveillants au sein du réseau.

> *Grâce au déploiement de notre nouvelle infrastructure Wi-Fi intégrant une authentification par certificat via EAP-TLS, seuls les périphériques disposant d'un certificat valide peuvent désormais accéder au réseau professionnel et aux différents serveurs de l'entreprise.*

Réaliser une veille technologique sur ce sujet m'est particulièrement bénéfique, car cela me permet d'approfondir mes connaissances sur le fonctionnement de l'authentification EAP-TLS et de mieux comprendre les enjeux de sécurité liés à sa mise en place au sein de mon entreprise.

2. Outils et méthodes de veille utilisés

2.1 Outils de surveillance automatisée

Afin de suivre l'évolution d'EAP-TLS sur 19 mois, plusieurs catégories d'outils ont été utilisées :

Agrégateurs et alertes

- Google Alerts : configuration d'alertes hebdomadaires sur les mots-clés « EAP-TLS », « RFC 9190 », « 802.1X certificate authentication », « WPA3 Enterprise EAP »
- Feedly (plan gratuit) : agrégation des flux RSS des sources principales (IETF, Microsoft Learn, Wi-Fi Alliance, Cisco Blogs)
- RSS de l'IETF (datatracker.ietf.org) : suivi des mises à jour des RFC et Internet Drafts du groupe de travail EMU

Plateformes techniques

- GitHub : surveillance des dépôts FreeRADIUS, hostapd, wpa_supplicant pour suivre les évolutions d'implémentation
- CVE Details / NVD NIST : surveillance des vulnérabilités liées aux implémentations TLS et EAP
- Packet Storm Security et Security Focus : veille sur les publications de PoC et recherches offensives

Sources institutionnelles

- IETF Datatracker (datatracker.ietf.org) : suivi des travaux du groupe EMU (EAP Method Update)
- Wi-Fi Alliance (wi-fi.org) : certifications WPA3 et communications officielles
- Microsoft Learn et documentation officielle : évolutions du support EAP-TLS dans Windows Server et Azure
- Sectigo, DigiCert, Let's Encrypt : bulletins sur les changements de politique PKI

2.2 Sources consultées

Catégorie	Sources principales	Fréquence de consultation
Normes et RFC	IETF Datatracker, RFC Editor, IANA	Mensuelle
Éditeurs logiciels	Microsoft Learn, Cisco DevNet, JumpCloud, SecureW2	Bimensuelle
Sécurité / CVE	NVD NIST, CVE Details, Packet Storm	Hebdomadaire
Organismes	Wi-Fi Alliance, ANSSI, NIST	Mensuelle
Presse spécialisée	LeMagIT, ZDNet, Dark Reading, The Hacker News	Hebdomadaire

2.3 Méthode de travail

La veille a été organisée selon un rythme régulier structuré en trois niveaux d'activité :

- Surveillance passive quotidienne : consultation des alertes Google et des flux Feedly (10-15 min/jour)

- Analyse hebdomadaire : lecture approfondie des articles pertinents, archivage dans Notion et classement par thématique
- Synthèse mensuelle : rédaction d'une note de veille récapitulative avec mise à jour du tableau de bord des événements marquants

Les informations collectées ont été classifiées selon quatre axes : évolutions normatives, évolutions des implémentations, actualités sécurité/vulnérabilités, et tendances marché/adoption.

3. Événements marquants de la veille

Le tableau suivant résume les événements les plus significatifs survenus durant la période de veille, classés par ordre chronologique.

Date	Événement	Importance
Sept. 2024	Publication du RFC 9427 : officialisation de l'utilisation de TLS 1.3 pour EAP-FAST, EAP-TTLS et TEAP, consolidant l'écosystème EAP-TLS 1.3 (RFC 9190).	**Majeur**
Oct. 2024	SecureW2 publie une analyse détaillée des failles des déploiements 802.1X basés sur des mots de passe. Recommandation forte de migrer vers EAP-TLS dans tous les environnements d'entreprise.	**Notable**
Nov. 2024	Recherche académique « Misbinding Raw Public Keys to Identities in TLS » publiée. Impact sur les implémentations EAP-TLS utilisant des clés publiques brutes (RPK) au lieu de certificats X.509 classiques.	**Critique**
Déc. 2024	JumpCloud annonce le renouvellement de son certificat RADIUS pour les environnements EAP-TTLS, avec mise à disposition d'un script PowerShell d'installation. Début des migrations PKI pour 2025.	**Notable**
Janv. 2025	Microsoft met à jour sa documentation Windows Server (NPS) pour EAP-TLS et PEAP-TLS. Ajout d'exigences explicites sur les certificats clients avec EKU id-kp-clientAuth pour la compatibilité WPA3.	**Majeur**
Fév. 2025	Verizon Data Breach Investigations Report préliminaire : 88 % des violations impliquent des identifiants compromis. Regain d'intérêt fort pour EAP-TLS comme alternative aux approches basées sur des mots de passe.	**Critique**
Mars 2025	Wi-Fi Alliance précise les exigences EAP pour WPA3-Enterprise 192 bits : EAP-TLS devient la SEULE méthode autorisée. Mise à jour du programme de certification des équipements.	**Critique**
Mai 2025	Sectigo annonce qu'à partir du 15 septembre 2025, l'EKU d'authentification client (id-kp-clientAuth) ne sera plus incluse par défaut dans les nouveaux certificats SSL/TLS publics.	**Majeur**
Juin 2025	Publication du rapport « Towards a new standard for network access authentication » (Computer Standards & Interfaces). Discussions sur l'évolution post-EAP-TLS.	**Notable**
Juil. 2025	JumpCloud installe les nouveaux certificats RADIUS sur ses serveurs. Interruptions de service signalées chez des clients n'ayant pas mis à jour à temps — exemple concret de l'enjeu du cycle de vie des certificats.	**Majeur**
Sept. 2025	Sectigo supprime officiellement l'EKU clientAuth des certificats publics. Les autorités de certification publiques ne peuvent plus émettre de certificats combinant serverAuth + clientAuth.	**Critique**
Oct. 2025	Publication de guides de déploiement 802.1X/EAP-TLS avec EJBCA (PKI open source) et JumpCloud RADIUS sur Ubuntu	**Notable**

	24.04. Démocratisation du déploiement EAP-TLS pour les PME.	
Nov. 2025	SecureW2 introduit le concept de « Dynamic PKI » : les certificats EAP-TLS sont validés en temps réel contre l'IdP et le MDM, pas uniquement lors de l'émission. Évolution majeure du modèle de confiance.	**Majeur**
Déc. 2025	Sectigo publie un guide complet sur la migration vers des CA privées pour l'authentification client TLS. Échéance de mai 2026 confirmée pour la suppression totale côté CA publiques.	**Critique**
Janv. 2026	Publication académique : « Towards a new standard for network access authentication » (volume 95). Proposition d'extensions à EAP-TLS pour l'IoT et les réseaux 5G.	**Majeur**
Fév. 2026	Microsoft met à jour ses pages de documentation EAP-TLS pour Windows Server 2025. Support natif de TLS 1.3 dans NPS confirmé. Suppression progressive de TLS 1.0/1.1 sur les serveurs RADIUS.	**Majeur**
Avr. 2026	Approche de l'échéance de mai 2026 : les organisations dépendant de CA publiques pour l'authentification client sont en phase critique de migration. EAP-TLS avec CA privée devient la norme de facto.	**Critique**

Légende : Critique = Impact structurant sur la technologie ou la sécurité Majeur = Évolution significative Notable = Information pertinente de veille

4. Résultats, Analyse finale et Conclusion

4.1 Synthèse des résultats de la veille

La veille menée sur 19 mois (septembre 2024 – avril 2026) a permis d'identifier quatre grandes tendances structurantes autour d'EAP-TLS :

Tendance 1 — Montée en puissance de TLS 1.3 dans l'écosystème EAP

La publication du RFC 9427 en 2024 a officialisé l'utilisation de TLS 1.3 pour l'ensemble des méthodes EAP basées sur TLS. Cette évolution apporte un gain de sécurité considérable : forward secrecy systématique, handshake réduit à un seul aller-retour, et suppression des suites cryptographiques obsolètes. Les implémentations open source (FreeRADIUS, wpa_supplicant) ont progressivement intégré ces nouvelles spécifications au fil de la période observée.

Tendance 2 — EAP-TLS, pilier incontournable de WPA3 et Zero Trust

La décision de la Wi-Fi Alliance de faire d'EAP-TLS la méthode exclusive pour le mode WPA3-Enterprise 192 bits est un signal fort. Couplée à l'émergence des architectures Zero Trust, EAP-TLS s'impose comme le fondement de la vérification des identités réseau : plus de confiance implicite basée sur un mot de passe, mais une identité prouvée cryptographiquement à chaque connexion.

Tendance 3 — Rupture majeure dans le modèle PKI public

L'événement le plus structurant de la période est sans conteste la décision des autorités de certification publiques de supprimer le support de l'authentification client (EKU clientAuth) d'ici mai 2026. Cette rupture force les organisations à migrer vers des PKI privées pour leurs déploiements EAP-TLS, ce qui représente un investissement et une complexité supplémentaires, mais aussi un gain en autonomie et en contrôle.

Tendance 4 — Automatisation et cycle de vie des certificats

Les incidents de service liés à des renouvellements de certificats RADIUS manqués (cas JumpCloud juillet 2025) illustrent un défi récurrent d'EAP-TLS : la gestion du cycle de vie des certificats à grande échelle. L'émergence de solutions de CLM (Certificate Lifecycle Management) et de PKI dynamiques (Dynamic PKI SecureW2) répond à ce besoin croissant.

4.2 Analyse critique

EAP-TLS est une technologie mature et éprouvée, mais sa complexité de déploiement reste son principal frein à l'adoption. Le besoin d'une PKI interne, la gestion des certificats clients sur tous les équipements (y compris BYOD et IoT), et la formation des équipes IT représentent des obstacles réels pour les organisations de taille moyenne.

Cependant, face à la montée des cybermenaces (88% des violations impliquant des identifiants compromis selon Verizon 2025), le rapport coût/bénéfice penche clairement en faveur d'EAP-TLS. Les solutions cloud (Cloud RADIUS, PKI managée) ont largement réduit la barrière à l'entrée, rendant le protocole accessible au-delà des grandes entreprises.

La période 2024-2026 marque un tournant : EAP-TLS n'est plus seulement recommandé, il devient progressivement obligatoire dans certains contextes normatifs (WPA3 192-bit, secteur public, industries réglementées).

4.3 Conclusion

Cette veille technologique de 19 mois a confirmé qu'EAP-TLS traverse une période charnière. Porté par l'adoption massive du Zero Trust, le renforcement des exigences WPA3 et la rupture du modèle PKI public, le protocole s'affirme comme la référence absolue pour l'authentification réseau basée sur des certificats.

Les organisations qui n'ont pas encore migré vers EAP-TLS font face à une urgence croissante, notamment avec l'échéance de mai 2026 pour les CA publiques. À l'inverse, celles qui ont anticipé ce changement bénéficient d'une posture de sécurité significativement renforcée et d'une conformité réglementaire assurée.

Sur le plan technique, l'intégration de TLS 1.3 (RFC 9190/9427) et l'émergence de la PKI dynamique représentent les avancées les plus notables de la période. À plus long terme, les travaux de recherche sur l'adaptation d'EAP-TLS aux réseaux 5G et à l'IoT laissent entrevoir une prochaine évolution majeure du protocole.

> *En conclusion, EAP-TLS n'est plus une option pour les environnements où la sécurité est un enjeu stratégique — c'est devenu une nécessité. La maîtrise de cette technologie, de son infrastructure PKI et de ses mécanismes de renouvellement automatisé est désormais une compétence clé pour tout professionnel des réseaux et de la cybersécurité.*

— Fin du rapport de veille technologique —